DEFEND THE TENANT CHALLENGE / PHASE 2

Microsoft 365 Security Hardening Plan

Prepared by: Jayden Morillo, BSc
Specialization: Information Technology and Microsoft 365 Security

A Zero Trust-first plan built for a 100-user organization with two administrators

CUSTOMER PROFILE	100 users • 2 administrators • Microsoft 365 E7
OPERATING REALITY	Limited admin time; security must be deployable, supportable, and recoverable
DESIGN PRINCIPLES	Assume breach; verify explicitly; use least privilege; automate carefully; validate before enforcement

Contents

AI use statement 3
Executive recommendation 4
Ranked top five controls 4
1. Enforce Zero Trust identity security and least-privilege access 5
2. Secure endpoints and adopt Zero Trust network access 10
3. Harden email and govern cloud/SaaS application use 13
4. Assume breach: detect, respond, and recover the tenant 15
5. Protect sensitive data, AI interactions, retention, and insider risk (Purview) 17
30-day implementation sequence 19
Microsoft references 20

AI use statement

ChatGPT was used to help formulate and express my ideas in written form. Claude was used to assist with document formatting and presentation. The security analysis, review, recommendations, and final design decisions were made by me. I reviewed the content to ensure the recommendations reflected my understanding and technical judgment.

Executive recommendation

Prioritize the attack paths that can cause the greatest business impact first, time is limited: compromised identities, excessive administrator privileges, unmanaged or vulnerable devices, phishing and unsanctioned SaaS, and sensitive-data exposure—including through AI-assisted workflows.

The five recommendations below combine prevention, detection, response, and recovery. They are intentionally designed as a small operating system for security rather than a checklist of every product feature. A control only counts as effective when its scope is understood, its behavior is tested, exceptions are owned, and evidence shows that it works. It is recommended to make sure that the posture aligns to the MITRE ATT&CK mitigations. (https://attack.mitre.org/mitigations/enterprise/)

Ranked top five controls

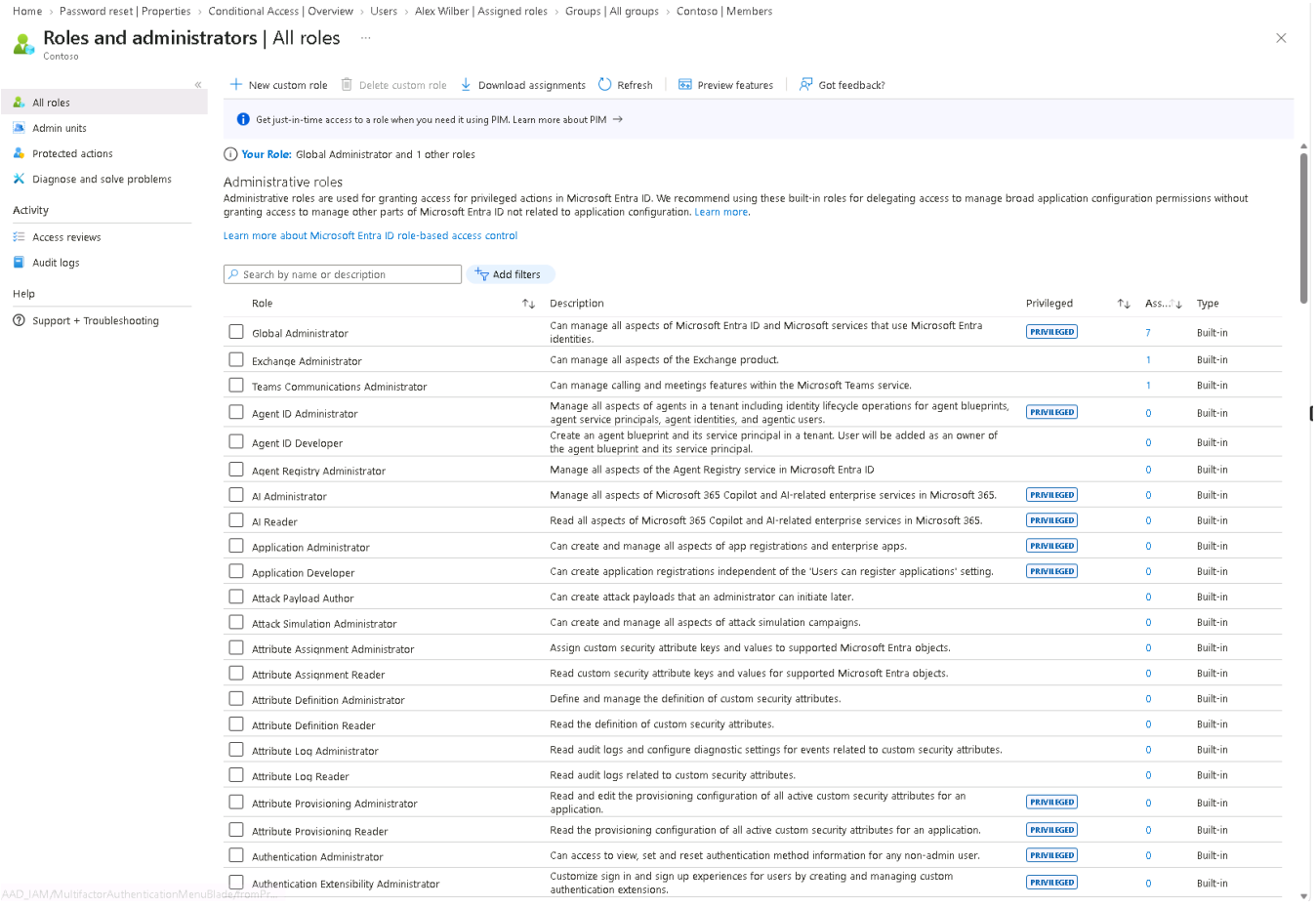
Rank	Control	Main risk addressed	Why it ranks here
1	**Zero Trust identity and privileged access**	Account takeover; tenant-wide control-plane compromise	Highest leverage: identities and privileged roles can unlock all other controls.
2	**Compliant devices and Zero Trust network access**	Compromised endpoints; broad network access	Reduces exposure from unmanaged devices and limits access to private resources.
3	**Email and SaaS application security**	Phishing, business email compromise, Shadow IT, risky OAuth apps	Addresses common entry and exfiltration paths with policy plus discovery.
4	**Assume-breach detection, response and tenant recovery**	Undetected compromise; slow or failed recovery	Improves detection, containment, and restoration when prevention fails.
5	**Purview data security, AI governance and insider risk**	Sensitive-data leakage, overexposure, misuse of AI	Protects information after access is granted and governs high-risk behavior.

1. Enforce Zero Trust identity security and least-privilege access

PRIORITY: CRITICAL **Begin with privilege discovery and secure access recovery**

Why it matters and risks reduced

Identity is the control plane for Microsoft 365. A compromised user can expose email and files; a compromised Global Administrator can weaken policies, change authentication, add principals, grant permissions, and disrupt the entire tenant. Zero Trust means explicitly verifying each access request, granting only the required permissions, assuming breach, and continually reassessing access—not simply enabling MFA.



The highest-risk pattern is an unnecessarily large set of permanent Global Administrator assignments. The supplied role-assignment screenshot shows seven active Global Administrator assignments in the demonstration environment: four user objects and three service principals. Because the screenshot is on the Active assignments tab and shows permanent assignments, it is a strong reason to audit standing privilege. Day-to-day administrators should normally be eligible for JIT activation rather than permanently active Global Administrators; the two emergency accounts remain permanently active for recovery. Investigate each service principal and user separately and make custom roles if they only need a certain type of permission also, remove the Global Administrators unless a documented, validated requirement makes it indispensable.

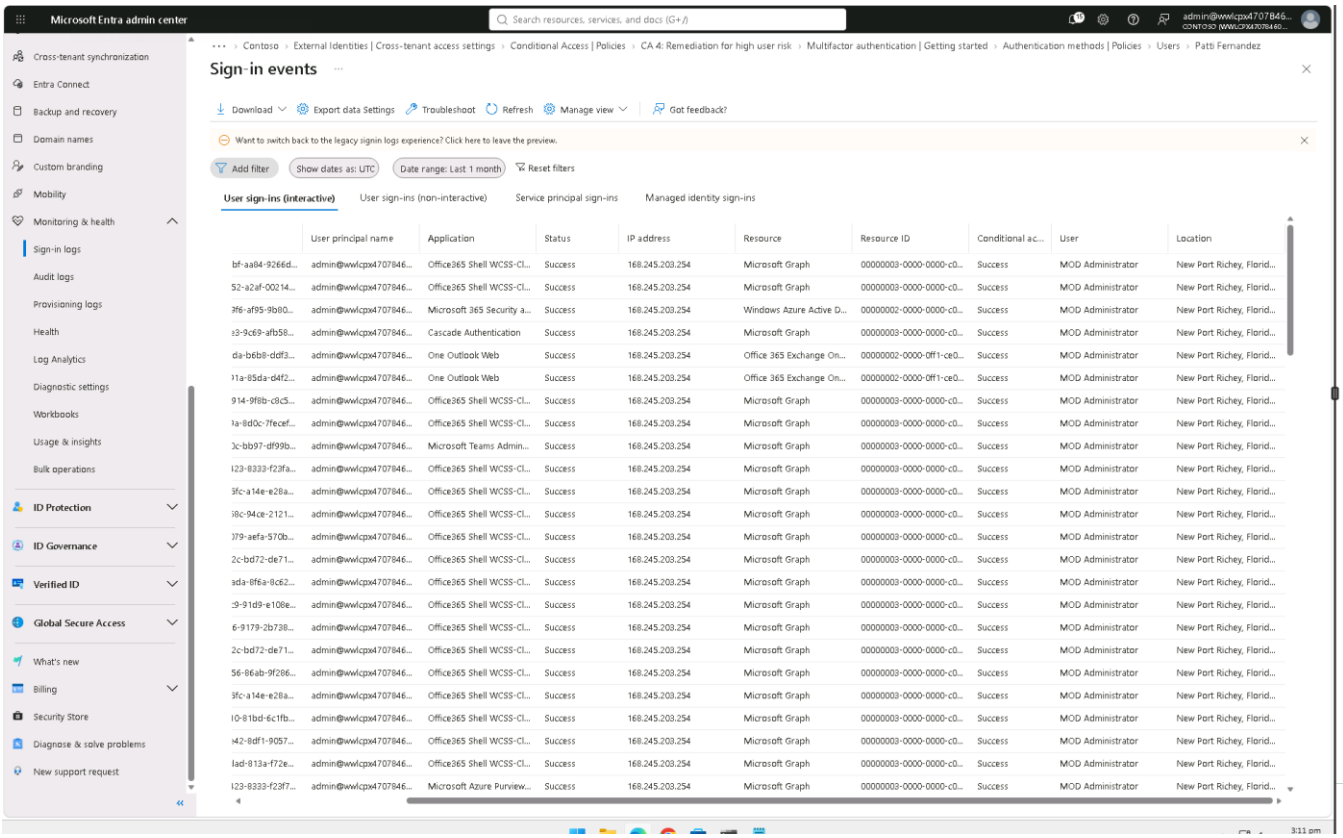
Recommended control design

Privileged roles and administrator accounts

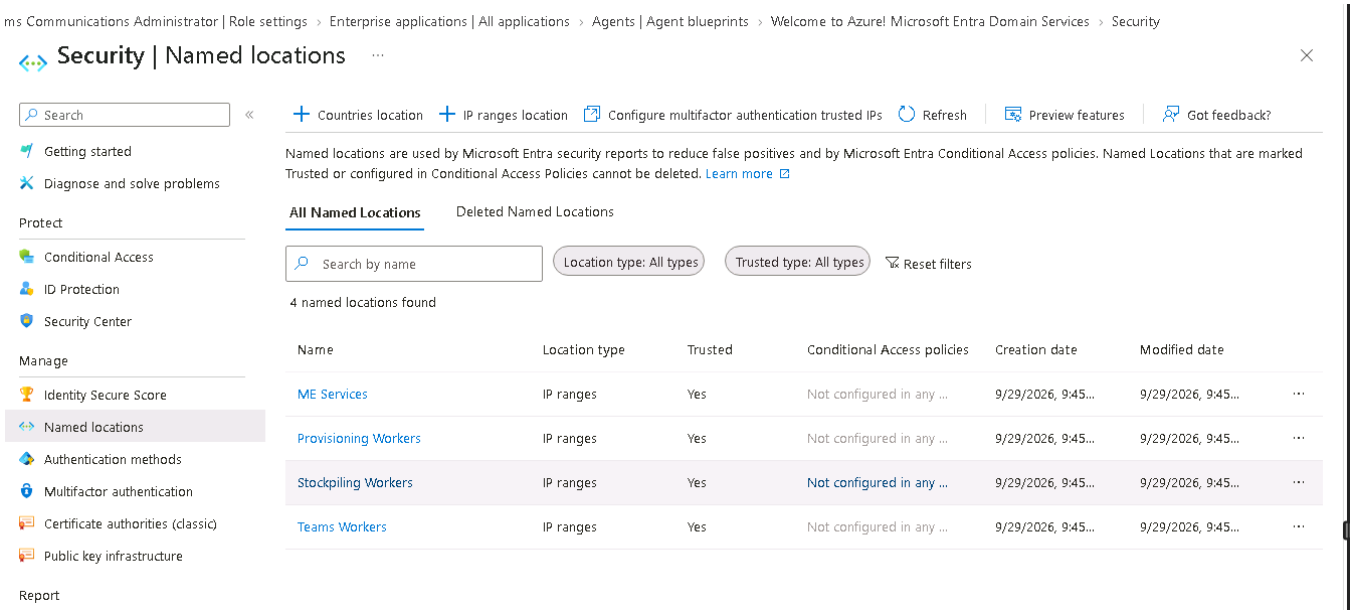
- **Human administrators:** create separate dedicated admin accounts for administrative work only, do not use obvious naming to avoid enumeration, addressing assume breach; ordinary accounts remain for Outlook, Word, PowerPoint, Teams, OneDrive, and SharePoint. Do not use admin accounts for routine browsing or mail. Secure admin workstations and require phishing-resistant authentication for high-privilege roles. Also, make sure messaging safety settings are on, allow numeric only passcode is off in the Teams admin center and score apps based on risk in Teams, and allow/block apps based on risk. E2E encryption should also be on for calls and meetings in Teams.
- **Just-in-time (JIT) privilege:** use Entra Privileged Identity Management (PIM) to convert routine privileged assignments to eligible, time-limited and just enough access activation for users, agents and apps. Require strong authentication, justification, alerts, and approval for the most sensitive roles where the two-admin operating model can support it. Use the narrowest built-in role that enables the task; create a custom role only when built-in roles are too broad and test the exact permission set or make use of administrative units.
- **Review Global Administrators separately:** for each human, confirm the actual recurring admin task and assign only that role (Exchange Administrator, Intune Administrator, Security Administrator, etc.) where sufficient. If the customer really has two administrators, those two should normally be eligible for day-to-day elevation rather than continuously active Global Administrators. Keep emergency-access identities separate, with strong passwords and (device bound) security keys, make sure alerts are on.
- **Workload identities:** the screenshot indicates three service-principal assignments in the example environment. Do not simply apply human-user PIM assumptions to them. Confirm each app's owner, purpose, sign-in activity, API permissions, credentials, and role use. Remove Global Administrator where not explicitly necessary; prefer managed identities, workload identity federation, certificates over long-lived client secrets, and least-privileged application roles. Add monitoring for credential and permission changes.
- **Attack-path assessment:** use BloodHound Community Edition for authorized Active Directory relationship analysis where applicable and AzureHound to collect Azure/Entra relationship data for BloodHound analysis. Keep scope read-only and approved, protect collected graph data as sensitive security data, and never publish raw collections. Prioritize paths from ordinary users, group owners, app/service principals, OAuth grants, and Azure RBAC roles to high-impact privileges; remediate the underlying permission or ownership edge and rerun the assessment to verify the path is closed. These are third-party assessment tools, not Microsoft 365 E7 features.
- **Group and license automation:** use Microsoft Entra dynamic user/device groups for repeatable Conditional Access targeting, app deployment, and group-based licensing, based on controlled attributes such as department, employeeType, or a governed extension attribute. Use security groups for access control and Microsoft 365 groups for collaboration where appropriate; apply a naming convention, accountable owner, purpose, data classification, and review date to each group.

Conditional Access policy baseline

- **Conditional Access baseline:** require MFA for all users; prioritize phishing-resistant authentication for administrators; block legacy authentication; use Entra ID Protection for risky sign-ins and users; require compliant devices for supported applications once device management is ready; and protect device registration and privileged portals.



- **Context-aware session controls:** use sign-in frequency/session controls for privileged roles and high-value admin resources, with stricter reauthentication for risky or sensitive admin actions. Avoid applying “Every time” to all users/resources by default; measure prompt frequency and business impact. Block device-code flow if sign-in logs show it is not needed. If the company truly operates only in the United States, use a named-location policy to block access from outside approved countries only after testing travel, contractors, VPNs, and IP geolocation edge cases.



- **Authentication-flow reduction:** in addition to blocking device-code flow when telemetry shows no business need, block Conditional Access authentication transfer when cross-device transfer is unnecessary. These are different flows. Use the Authentication flows condition, test in report-only mode, inspect sign-in logs, and exclude emergency accounts.
- **Guest and external-user sessions:** use a dedicated Conditional Access policy for guest/external identities with a risk-appropriate sign-in frequency and MFA requirements. Validate cross-tenant access settings and collaboration workflows; use shorter sessions for sensitive guest access only when business needs support it. This is because you have less control over guest users.

Authentication methods and passwords

- **Passkeys by privilege tier:** configure and require Microsoft Entra passkey (FIDO2) profiles for target groups via conditional access. For Global Administrators, prefer a profile restricted to device-bound passkeys (such as supported FIDO2 security keys); for other administrators, allow device-bound and synced passkeys if the organization accepts the different assurance that type of balance between security and user experience. Enforce the intended method using profile scope and an appropriate Conditional Access authentication strength, and test enrollment and recovery before enforcement. Microsoft is also moving toward passwordless, so it future-proofs the organization.
- **Password defense and lockout:** enable Microsoft Entra Password Protection custom banned terms for actual company names, brands, product names, internal terms, and relevant locations; keep the list focused and test matching behavior. For the Contoso scenario, candidate terms may include “Contoso,” “San Jose,” “California,” “Des Moines,” “Iowa,” “New Port Richey,” and “Florida” if these reflect the organization’s identifiers, locations, or likely password choices. Include meaningful variants, but do not assume every geographic term must be blocked without testing and business context. Train users to use phrases as passwords and make sure it’s something easy to remember and something private, like “My favorite food is peas and $teak3” with 3 being the jersey number of your favorite athlete, they should make sure that easy to remember phrases shouldn’t include public information. Set Microsoft Entra Smart Lockout threshold to 10 or less and tune lockout duration. require arbitrary periodic password changes for cloud users. Prioritize strong MFA/passkeys and change passwords when compromise is suspected or confirmed. Compromise can be seen via haveibeenpwned. Because sometimes users use the same passwords, this should be addressed and discouraged in employee trainings. Also passwords must include numbers and special characters and a capital letter and also a normal letter, and passwords should be atleast 8 characters long, in order to keep up with quantum computing.
- **SSO:** enable SSO to applications when it reduces password reuse, facilitates user experience and increases security. Pair SSO with enterprise app consent controls, vetted publishers, least-privilege delegated/application permissions, provisioning/offboarding, and periodic access reviews.

Emergency access and safe enforcement

- **Two emergency-access accounts:** create at least two cloud-only, non-personal accounts that are independent of normal federation and user devices. Use non-obvious identifiers if organizational practice supports it, but never rely on obscurity as the only security control, in regards to defense in depth; keep recovery details in a controlled offline runbook accessible to authorized administrators. Use distinct phishing-resistant authentication methods and separately secured credentials, maintain permanent active Global Administrator access for genuine emergency use, and exclude these accounts from Conditional Access policies that would block or restrict sign-in. Alert and audit on any use, and test sign-in at least quarterly (Microsoft guidance says regularly, such as every 90 days). Do not use these accounts for routine work.
- **Validate before enforcing:** use Conditional Access report-only mode, the What If tool, sign-in logs, and assess policy impact; test pilot users and representative apps; document rollback; then stage rollout to all users. Evaluate Secure Score and Identity Secure Score as global signals, but do not blindly chase points if a recommendation interrupts specific company critical operations or creates a larger exposure.

Practical rollout for two administrators

1	Export current role assignments for directory roles and enterprise apps, identify all human and service-principal Global Administrators, identify owners, inspect last sign-ins and permissions, and record the current state before edits.
2	Classify each principal as day-to-day admin, emergency access, automation/workload, or unknown. For unknown principals, disable/remove only after confirming ownership and dependencies; preserve the evidence and change record.
3	Create dedicated admin accounts and harden their sign-in path. Map the two administrators' routine duties to least-privileged roles and configure PIM eligibility, short activation duration, justification, notifications, and approvals selectively.
4	Create and test two independent emergency-access accounts, alert on sign-in and role/configuration changes.
5	Pilot Conditional Access policies in report-only mode, use What If and sign-in logs, test emergency access and line-of-business apps, then enforce in waves. Review policy results and exclusions after each wave.

Trade-offs and safeguards

JIT activation and stronger authentication add friction, and approval gates can delay work when one administrator is absent. Too few privileges can break automation; too many recreate standing risk. Requiring every-time sign-in or blocking all non-US locations can disrupt work and travel. Manage trade-offs with role mapping, tested recovery, short time-bound exceptions, a backup approver where feasible, and measurable sign-in impact. Service principals need workload-identity controls rather than a copied human-user policy. It is important to find the right balance for your company.

Validation and success measures

- ✓ Count of standing human Global Administrators and Global Administrator service principals; every remaining assignment has a documented owner and business justification.
- ✓ Percentage of day-to-day privileged roles configured as eligible/JIT; activations have authentication, justification, and audit evidence.
- ✓ Percentage of administrators using phishing-resistant authentication; MFA enforcement and legacy-authentication block validated in sign-in logs.
- ✓ Conditional Access exclusions have a purpose.
- ✓ Two emergency accounts independently tested; alerts are confirmed; no routine sign-in from these accounts.
- ✓ Identity Secure Score and overall Secure Score reviewed monthly, with documented accept/mitigate decisions rather than score-chasing.

2. Secure endpoints and adopt Zero Trust network access

PRIORITY: HIGH **Pilot in waves after identity baselines**

Why it matters and risks reduced

MFA cannot guarantee that a device or session is safe. Malware, unpatched browsers/operating systems, stolen tokens, and unmanaged endpoints can expose cloud data. Broad network access also lets a compromised device reach resources it does not need. Pairing Intune, Defender for Endpoint, and Global Secure Access connects device health and identity to access decisions.

Use Intune to manage supported corporate devices and enforce a practical baseline; use Defender for Endpoint for endpoint detection, vulnerability prioritization, and response. Use Microsoft Entra Global Secure Access—Private Access and Internet Access—where it fits the network and application design to move toward identity-aware, least-privilege access instead of a flat network trust model.

Recommended control design

Corporate device management and hardening

- Enroll supported corporate Windows and mobile devices in Intune; use update rings and supported-version policies to keep Windows and Edge within approved security update levels. Use Defender Vulnerability Management/reporting to prioritize exploitability and severity rather than simply chasing “latest” versions without change testing.
- Reduce onboarding effort with Windows Autopilot user-driven deployment for the 100-user population: register devices through the OEM/partner when possible, use a dedicated dynamic device group to assign the Autopilot profile, and deploy the standard configuration/apps through Intune. User-driven provisioning lets staff complete first-start setup without an administrator configuring each device manually; pilot one representative hardware/app set first.
- **Use the Company Portal intentionally:** assign mandatory baseline and security apps as Required, optional approved apps as Available, and uninstall unapproved apps.
- **Application control and attack-surface reduction:** pilot App Control for Business (Windows code-integrity policy) and relevant Defender Attack Surface Reduction rules. For example, consider “Block JavaScript or VBScript from launching downloaded executable content”, Blocking jailbroken devices, having strong lock screen authentication, requiring encryption, requiring TPM, firewall, LSA, code integrity and “Block executable content from email client and webmail.” Start in audit mode, measure compatibility, then enforce in waves; validate signed business scripts, line-of-business apps, and kernel/driver compatibility before expanding policy scope.
- **Windows local administrator passwords:** configure Windows LAPS through Intune for supported managed Windows devices, use a single non-conflicting LAPS policy per target device group, back up passwords to the supported directory, restrict who can retrieve them, and verify scheduled/manual rotation.

BYOD and mobile devices

- **BYOD:** where full enrollment would be intrusive or impractical, use supported Intune app-protection policies and Conditional Access to restrict corporate data to approved apps, prevent unmanaged data transfer where supported, and enable selective wipe of organizational data. Define explicit limits of control over personal devices. For unmanaged Windows endpoints, use supported app-enforced restrictions (for example, browser-only/limited download access for SharePoint and OneDrive where applicable)

- **Android biometric assurance:** do not assume all face unlock implementations are equally secure. For supported Android Enterprise enrollment types and OS versions, use Intune device restrictions to prevent weak biometrics where the platform exposes that distinction, require appropriate password/PIN complexity, and configure a reasonable strong authentication recheck interval. Validate the exact setting per Android version, OEM, and enrollment type; Android 12+ uses different password-complexity controls than older releases. Block face unlock only on device classes whose biometric assurance fails the organization's requirements, not as an untested universal rule.

  https://www.youtube.com/watch?v=9c55N6FFyrs

Device health and compliance

- **Device integrity and live health:** require Secure Boot on supported Windows hardware, apply supported OS/browser update rings, enable Defender Antivirus real-time and cloud-delivered protection, and onboard endpoints to Defender for Endpoint. Connect Defender device-risk signals to Intune compliance (for example, a "Low or below" machine risk threshold as a balanced starting point) and then Conditional Access after test devices prove the signal flow.
- **Apply baseline controls:** active endpoint protection and current security intelligence, firewall, disk encryption, secure boot where available, attack-surface reduction in audit/pilot then enforcement, and a remediation path for noncompliant devices.
- Build compliance policies around supported OS version, encryption, firewall, antivirus/EDR health, and other available signals. Connect device compliance to Conditional Access for supported resources after pilot validation.

Zero Trust network access

- Pilot Global Secure Access Private Access for selected internal/private applications and Internet Access for suitable outbound web traffic. Define traffic profiles and resource-specific access before broad deployment; confirm client, connector, routing, licensing, and application prerequisites.

Practical rollout for two administrators

1	Inventory device ownership, OS/browser versions, security tooling, critical apps, device locations, and current remote-access paths.
2	Pilot Intune enrollment, update rings, baseline settings, and Defender for Endpoint onboarding with IT and a small representative group; resolve app incompatibilities.
3	Define compliance grace periods and a remediation/help path. Confirm that devices report healthy state reliably before using compliance to block access.
4	Pilot Global Secure Access for a small set of internal applications and appropriate web traffic; verify access logs and ensure rollback routes remain available.
5	Roll out in waves based on device readiness; use reports to prioritize high-risk devices and expire exceptions.

Trade-offs and safeguards

Legacy devices, specialist software, remote networks, VPNs, and personal devices can complicate rollout. Strict compliance can block work if the device is stale or telemetry fails; access clients/connectors can add troubleshooting overhead. Use supported baselines, short pilot cycles, business-owned exceptions, clear help instructions, and ensure the chosen GSA features are licensed and technically applicable before committing to universal deployment.

Validation and success measures

- ✓ Percentage of supported corporate devices enrolled in Intune and reporting in Defender for Endpoint.
- ✓ Percentage meeting the agreed baseline, and count of unpatched critical/high vulnerabilities older than the remediation SLA.
- ✓ Endpoint protection and security intelligence status; local-administrator exceptions reviewed.
- ✓ Access to selected private applications is limited to the correct identity/device/context, with no unexpected business interruption during pilot.
- ✓ Conditional Access device-compliance decisions validated through sign-in logs and test cases.

3. Harden email and govern cloud/SaaS application use

PRIORITY: HIGH **Rapidly reduce common entry and exfiltration paths**

Why it matters and risks reduced

Phishing and business email compromise can trigger fraudulent payments, credential theft, malware delivery, and data theft. Separately, users may adopt SaaS apps or OAuth integrations that store business data outside approved controls. Email gateway settings alone are not enough; combine Defender for Office 365 with Exchange Online configuration and Shadow IT discovery.

The goal is to protect inbound/outbound mail, reduce risky mail-flow features, detect SaaS usage, and block apps that the organization has deliberately designated as unsanctioned. Policies must reflect the actual business: finance impersonation risks, approved collaboration apps, external sharing, and legitimate automation.

Recommended control design

Email protection and mail flow

- In Defender for Office 365, review anti-phishing/impersonation, anti-malware, anti-spam, Safe Links, Safe Attachments, spoof intelligence, and suitable Standard/Strict preset security policies. Protect executives, finance, and payment approvers with tailored impersonation protection. Add these to quarantine, junk, or delete based off risk. Review Quarantine regularly for false positives.
- Train users to recognize phishing, social engineering, spam and malicious email and links. Validate with Attack Simulation Training, first couple of weeks with phishing then making it progressively more difficult with spear phishing.
- For Exchange Online recipients, use Safe Attachments Dynamic Delivery where the effective policy and business requirements support it: deliver the message body with attachment placeholders while scanning continues, make attachments available only after a safe verdict, and quarantine malicious attachments. Test actual policy precedence and desktop/mobile experience.
- Verify that every business sending domain is owned and verified in the tenant and that DNS is managed securely. For each sending domain, inventory legitimate senders, publish one valid SPF record, enable DKIM signing, and deploy DMARC in monitoring mode before moving to quarantine/reject as reports confirm alignment. Review subdomains and third-party senders; avoid breaking legitimate mail by enforcing reject before the inventory is complete.
- In Exchange Online, review outbound automatic forwarding and block external auto-forwarding by default except approved business cases; disable or restrict SMTP AUTH where not needed; check inbound/outbound connectors, remote domains, allow lists, mailbox auditing, and outbound spam controls. Publish and validate SPF, DKIM, and DMARC for domains. Use transport rules, such as clearly marking external messages, only where they help users and do not create alert fatigue.

Cloud and SaaS application governance

- Enable Defender for Cloud Apps Cloud Discovery using supported log collection or Defender for Endpoint integration. Inventory discovered apps and OAuth consent grants; review publishers, permissions, data access, traffic, and business owner before sanctioning or blocking.
- **Use a proposed triage threshold:** score 1–3 as high-priority block/unsanction apps and 4–6 as alert/review apps, this is a customer-tuned policy proposal, not a Microsoft-mandated universal threshold.

- Confirm Defender for Endpoint, secure web gateway, or other supported enforcement integration and allow time for app-domain propagation.

Practical rollout for two administrators

1	Capture current mail flow, domain DNS authentication, forwarding settings, SMTP AUTH usage, connectors, external sharing workflows, and known business-critical SaaS apps.
2	Pilot email protection policies with finance and executives, review quarantines and impersonation results, and tune false positives before broad enforcement.
3	Validate SPF/DKIM/DMARC alignment and apply external forwarding restrictions; create documented exceptions for approved systems only.
4	Enable cloud discovery, review apps by risk factors and usage, and meet business owners before blocking. Test unsanctioned-app enforcement on a small pilot before expanding.
5	Review OAuth apps and user/admin consent, remove stale grants, and monitor new high-risk app permissions; publish a short user guidance page for reporting suspicious messages and requesting app approval.

Trade-offs and safeguards

> Email controls can quarantine legitimate messages, and forwarding or SMTP AUTH changes can break business workflows. Cloud app risk scores may not capture contract terms, data residency, or the business need for an application; automatic blocking by score alone risks productivity. Start in monitoring mode, confirm actual score semantics, validate dependencies, communicate policy, and require an owner-approved exception with expiry.

Validation and success measures

- ✓ SPF, DKIM, and DMARC are present and pass validation for business domains, with a staged DMARC enforcement plan where needed.
- ✓ External auto-forwarding and SMTP AUTH are restricted to documented exceptions; connector and allow-list changes are audited.
- ✓ Phishing simulation/incident trends, malicious URL/attachment detections, and false-positive quarantine rates are reviewed.
- ✓ Dynamic Delivery test: confirm the placeholder is shown during scanning, a benign test attachment becomes available after a safe verdict, and a controlled malicious-test scenario is quarantined; document unsupported scenarios and effective policy precedence.
- ✓ Cloud Discovery coverage is established; unsanctioned app policy test results prove the intended block is enforced on supported endpoints.

4. Assume breach: detect, respond, and recover the tenant

PRIORITY: HIGH **Start runbooks and critical alerts in parallel**

Why it matters and risks reduced

Prevention will fail sometimes. A small team needs an operationally simple way to detect suspicious activity, contain compromised identities/devices, and restore a tenant after malicious or accidental changes. The goal is not to monitor every alert manually, but to prioritize high-impact signals and rehearse recovery before a crisis.

Use the Defender XDR incident queue to correlate email, endpoint, and identity signals; define severity-based ownership; alert on emergency-account use, unexpected privileged-role changes, suspicious authentication and risky OAuth grants. Add one carefully controlled identity decoy/honeytoken to apply defense in depth.

Recommended control design

Response and recovery readiness

- Create a concise response playbook for suspected account compromise, malicious inbox rules/forwarding, ransomware or compromised endpoint, risky OAuth app, and tenant-wide admin lockout. Define who can disable sessions/accounts, revoke tokens, isolate devices, remove malicious grants, preserve evidence, and contact Microsoft support.
- Build an external, versioned, snapshot of tenant configuration using supported exports/APIs; retain sign-in/audit logs long enough for investigation. Document Recovery Time Objective (RTO) and Recovery Point Objective (RPO) and check which objects/services have built-in recovery support. Also, have M365, Entra and Azure Backups in place.

Detection, threat intelligence and AI assistance

- Review threat intelligence daily for urgent/high-confidence alerts and campaigns; filter relevance to the organization's sector, geography, technologies, exposed apps, and business processes. Do not overload two administrators with generic threat feeds. Convert relevant intel into concrete searches, detections, patches, blocking, or user warnings.
- **Optional decoy identity:** create one unprivileged, unlicensed test identity with no mailbox, business data, app permissions, or directory roles; use a plausible but non-sensitive identifier (for example, an admin-style lure label such as 'GA1' if that fits the threat model and does not collide with a real identity) and never use it for real work. Alert on any sign-in attempt for that identity, investigate source and outcome, and ensure the event reaches the incident queue. Do not assign Global Administrator or other privileges to a honeytoken.
- Configure an alert on any use of the two emergency-access accounts and high-impact audit events such as role assignment, Conditional Access modification, new credentials on service principals, unusual consent grants, or disabling security controls.
- **Security Copilot:** use the capability included with eligible Microsoft 365 E7 subscriptions to assist with incident summarization, hunting-query drafting, investigation context, and triage of relevant threat intelligence. Confirm that the capability is provisioned in the tenant and within the organization's rollout/region. Treat outputs as analyst assistance: validate queries and conclusions, apply role-based access and data-handling rules, and require human approval for disruptive containment or configuration changes.
- **Microsoft Sentinel:** use Sentinel to identify alerts and incidents that give context to alerts, to remediate them. Sentinel is used for SIEM/SOAR.

Exercises and drills

- Run incident tabletop exercises and recovery drills. Follow Microsoft's tenant recoverability guidance to retain a best practice configuration, define recovery steps, restore objects where supported, and re-enable/revalidate Conditional Access after recovery.(https://learn.microsoft.com/en-us/answers/questions/5556277/how-to-regain-access-to-a-microsoft-365-tenant-aft) (https://learn.microsoft.com/en-us/entra/architecture/recoverability-overview)

Practical rollout for two administrators

1	Assign an incident owner and backup; map each high-severity alert to one clear response procedure and escalation contact.
2	Configure alerts in the available Microsoft security stack; test delivery by generating safe, planned test events rather than waiting for a real compromise.
3	Create a recovery checklist and periodic exports of configuration, role assignments, Conditional Access policies, app registrations/permissions, and critical security settings. Store the exports outside the tenant with access controls and versioning.
4	Create the optional unprivileged decoy identity only after alerting, log retention, privacy review, and response ownership are working. Verify the alert fires for a harmless test attempt and that no real workflow depends on that identity.
5	Run a tabletop in month one and a recurring quarterly drill for emergency access, compromised administrator, and tenant configuration recovery; track lessons to closure.

Trade-offs and safeguards

Decoy accounts can generate noise and require careful governance; they must not contain real data or privileges and must never masquerade as an actual employee. Excessive alerting overwhelms a small team, while overly aggressive auto-remediation can disrupt business. Limit alerts to actionable high-impact signals, start with high-confidence automation, protect recovery exports, and test every runbook. Do not rely on Microsoft support as a substitute for emergency-access accounts or recovery planning.

Validation and success measures

- ✓ High-severity alerts are acknowledged and triaged within a documented target; ownership and backup coverage are tested.
- ✓ Alert tests for emergency access, privileged-role changes, and decoy identity reach the correct response channel.
- ✓ Configuration snapshots are versioned and stored outside the tenant; a restoration drill is completed and RTO/RPO documented.

5. Protect sensitive data, AI interactions, retention, and insider risk (Purview)

PRIORITY: HIGH **Prioritize the highest-impact data first**

Why it matters and risks reduced

Identity and endpoint protections control who can reach data, but they do not fully prevent oversharing, inappropriate use by a legitimate user, or sensitive information entering AI prompts and responses. The organization needs clear data handling rules, technical DLP enforcement, retention requirements, and a proportionate way to identify potentially risky insider behavior.

Use Microsoft Purview sensitivity labels, adaptive protection, DLP, retention policies, and Insider Risk Management in combination with permissions hygiene. For AI, configure the Microsoft 365 Copilot and Copilot Chat DLP location to prevent processing of appropriately labeled sensitive files/emails and to restrict prompts containing configured sensitive information types where the feature and licensing are available. Do not assume that simply enabling labels automatically blocks AI processing.

Recommended control design

Classify and protect data

- **Classify the highest-value information first:** customer records, financial information, personnel data, regulated records, intellectual property, credentials/secrets and create EDM's if necessary. Create a small label taxonomy (Public, Internal, Confidential, Highly Confidential) with clear guidance and appropriate encryption/marking where needed.
- Create DLP policies for Exchange, SharePoint, OneDrive, Teams, and relevant endpoint/AI locations according to the actual data flow and service support. Start with audit/simulation and policy tips; enforce high-confidence rules only after reviewing matches and false positives.

AI interactions and oversharing

- For Microsoft 365 Copilot/Copilot Chat, create rules using sensitivity labels to prevent Copilot from processing selected sensitive files/emails; use supported sensitive-information-type rules to block sensitive prompts or external web-search grounding where desired. Validate the exact supported location, condition, and action in current Microsoft documentation.
- **Fix oversharing at source:** review SharePoint and OneDrive external sharing, stale links, broad groups, and excessive permissions. Copilot operates in the initiating user's permission context; DLP and labels reduce processing risk but do not replace access hygiene.

Insider risk and retention

- Enable an appropriate Purview Insider Risk Management policy (including the Risky AI usage template if relevant and available) using least-privileged role access, privacy controls, clear escalation criteria, and consultation with legal/HR where appropriate. Make sure prompts including sensitive company data do not get searched in Copilot.
- Create retention and deletion policies based on legal/business needs.

Practical rollout for two administrators

1	Identify the top three to five sensitive data types, where they live, who owns them, and the applicable legal/business retention needs.
2	Publish a small label set and pilot with a business group; test labeling behavior in common Office and collaboration workflows.
3	Run Purview DLP policies in simulation/audit mode where supported, review sample matches, tune false positives, and document legitimate exceptions.
4	Configure Copilot/Copilot Chat DLP with selected labels and sensitive information types where supported; test file references, prompts, and web-search restrictions with safe test data.
5	Enable a narrowly scoped Insider Risk policy, assign limited reviewers, set escalation rules, and explain the policy to relevant stakeholders while respecting privacy and labor requirements.
6	Enforce priority DLP rules in waves; publish user-facing policy tips and review incidents, retention settings, and exceptions monthly.

Trade-offs and safeguards

DLP and labels may interrupt legitimate collaboration if classification is wrong; Insider Risk Management raises important privacy, fairness, and employee-relations considerations. Some AI protections have experience/location/condition limitations, and DLP cannot inspect every uploaded item in every prompt scenario. Test against the actual Copilot experiences deployed, explain the policy to users, consult legal/HR where required, and never claim DLP protects an interaction that the selected policy does not cover.

Validation and success measures

- ✓ Priority repositories have clear owners, labels, sharing permissions, and retention rules.
- ✓ Copilot DLP test cases prove the selected sensitive files/prompts are blocked or restricted as intended; logs confirm policy evaluation.
- ✓ DLP false-positive rate, overrides, and exceptions have owners and review dates.
- ✓ Insider Risk policies are scoped, access to case details is limited, and escalation decisions are documented.
- ✓ Unnecessary external sharing and orphaned access links are reduced; retention rules align with legal/business requirements.

IMPLEMENTATION NOTE

Purview DLP for Microsoft 365 Copilot/Copilot Chat has specific supported conditions and actions. For example, sensitivity-label rules can prevent processing of selected labeled files/emails, while sensitive-information-type rules can restrict certain prompts or external web searches. Verify current support and licensing before deployment.

30-day implementation sequence

> This is an initial stabilization roadmap, not a promise that every control can be fully rolled out in 30 days. Prioritize any confirmed critical exposure immediately. Expand only after compatibility and access impact are validated.

Window	Focus	Actions	Exit evidence
Days 1–3	Discovery and recovery	Inventory role assignments, service principals, apps, mail flow, devices, data, and existing policies. Test emergency access and capture known-good configuration.	Confirmed baseline; critical findings ranked; recovery path tested.
Days 4–10	Identity and privilege	Reduce unnecessary standing privilege; configure dedicated admin accounts and PIM; pilot MFA, risky sign-in, device-code, session, and location policies.	Role mapping; report-only/What If evidence; emergency accounts tested.
Days 8–17	Endpoints and access	Pilot Intune/Defender baselines and compliance; test Global Secure Access for selected apps and traffic.	Devices report accurately; pilot validates access and rollback.
Days 12–21	Mail and cloud apps	Harden Defender/Exchange; validate domain email authentication; discover SaaS/OAuth use and pilot app governance.	Mail-flow test results; Shadow IT enforcement test.
Days 18–27	Data, AI and recovery	Pilot labels/DLP, Copilot protections and Insider Risk; configure high-impact detections, threat triage and runbooks.	DLP test evidence; incident alerts and response drills.
Days 28–30	Handover and review	Enforce validated policies in stages; close critical gaps; document exceptions; present monthly metrics and owners.	Evidence pack, review cadence and action log agreed.

Microsoft references

Links are grouped by topic.

Challenge and licensing

Official Defend the Tenant Challenge rules	https://github.com/microsoft/Defend-the-Tenant-Challenge/blob/main/OFFICIAL%20RULES.md
Microsoft 365 E7 plan overview	https://www.microsoft.com/en-us/microsoft-365/enterprise/e7

Identity, access and Zero Trust

Emergency access accounts	https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/security-emergency-access
Microsoft Entra PIM overview	https://learn.microsoft.com/en-us/entra/id-governance/privileged-identity-management/pim-configure
Conditional Access session controls / sign-in frequency	https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-session
Conditional Access authentication flows / device code	https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-authentication-flows
Conditional Access report-only and validation	https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-report-only
Microsoft Zero Trust deployment for Microsoft 365	https://learn.microsoft.com/en-us/security/zero-trust/microsoft-365-zero-trust How attackers get around MFA, and what stops them | Ask a Cybersecurity Pro
Microsoft Entra passkey profiles, synced and device-bound passkeys	https://learn.microsoft.com/en-us/entra/identity/authentication/how-to-authentication-synced-passkeys
Microsoft Entra custom banned password list	https://learn.microsoft.com/en-us/entra/identity/authentication/concept-password-ban-bad
Microsoft Entra Zero Trust identity guidance and Smart Lockout	https://learn.microsoft.com/en-us/entra/fundamentals/zero-trust-protect-identities
Microsoft Entra dynamic membership groups	https://learn.microsoft.com/en-us/entra/identity/users/groups-dynamic-membership
Conditional Access: authentication transfer	https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-authentication-transfer

Endpoints and network access

Microsoft Entra Global Secure Access	https://learn.microsoft.com/en-us/entra/global-secure-access/
Windows Autopilot user-driven mode	https://learn.microsoft.com/en-us/autopilot/user-driven
Intune Android Enterprise device restrictions and biometric options	https://learn.microsoft.com/en-us/intune/intune-service/configuration/device-restrictions-android-for-work
Deploy Windows LAPS with Intune	https://learn.microsoft.com/en-us/intune/intune-service/protect/windows-laps-policy
Intune app assignments: Required, Available and Uninstall	https://learn.microsoft.com/en-us/intune/app-management/deployment/assign-groups
App Control for Business feature availability	https://learn.microsoft.com/en-us/windows/security/application-security/application-control/app-control-for-business/feature-availability
Defender for Endpoint Attack Surface Reduction rules	https://learn.microsoft.com/en-us/defender-endpoint/attack-surface-reduction

Intune and Defender for Endpoint device-risk compliance integration	https://learn.microsoft.com/en-us/intune/device-security/microsoft-defender/configure-integration

Email and SaaS security

Defender for Cloud Apps risk scoring	https://learn.microsoft.com/en-us/defender-cloud-apps/risk-score
Defender for Cloud Apps cloud discovery policies	https://learn.microsoft.com/en-us/defender-cloud-apps/policies-cloud-discovery
Defender for Cloud Apps and Defender for Endpoint: investigating apps	https://learn.microsoft.com/en-us/defender-cloud-apps/mde-investigation
Exchange Online mail flow and SPF/DKIM/DMARC best practices	https://learn.microsoft.com/en-us/exchange/mail-flow-best-practices/mail-flow-best-practices
Safe Attachments and Dynamic Delivery	https://learn.microsoft.com/en-us/defender-office-365/safe-attachments-about

Detection, response and recovery

Tenant recoverability	https://learn.microsoft.com/en-us/entra/architecture/recoverability-tenant
Microsoft Q&A: recovering access after all admins are deleted (scenario reference)	https://learn.microsoft.com/en-us/answers/questions/5556277/how-to-regain-access-to-a-microsoft-365-tenant-aft
BloodHound Community Edition documentation	https://bloodhound.specterops.io/
AzureHound official collector repository (SpecterOps)	https://github.com/SpecterOps/AzureHound
Microsoft 365 E5/E7 Security Copilot inclusion	https://learn.microsoft.com/en-us/copilot/security/security-copilot-inclusion

Data protection and AI

Purview DLP for Microsoft 365 Copilot/Copilot Chat	https://learn.microsoft.com/en-us/purview/dlp-microsoft365-copilot-location-learn-about
Purview Insider Risk Management	https://learn.microsoft.com/en-us/purview/insider-risk-management

Supplementary (not authoritative)

Windows Hello vs iOS vs Android	https://www.youtube.com/watch?v=9c55N6FFyrs